Министерство образования Республики Беларусь
Учреждение образования
«Брестский государственный технический университет»
Кафедра ИИТ

Лабораторная работа № 2
За седьмой семестр

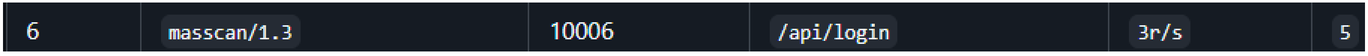
Тема: «Защита веб-периметра и ограничение интенсивности сетевого трафика средствами межсетевых экранов прикладного уровня»

Выполнил:
Студент 4 курса
Группы ИИ-26
Згера Е. А.
Проверил:
Хацкевич А.С.

2026

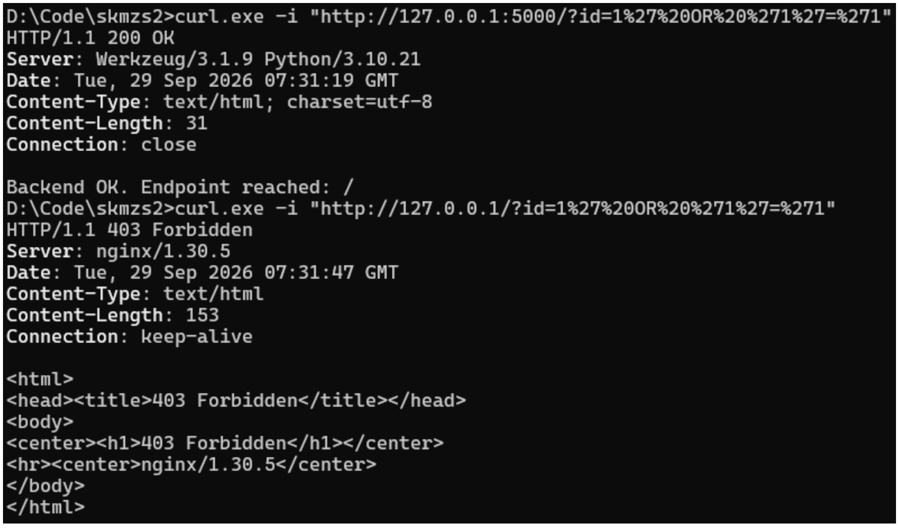
Вариант 5

Цель: практическое освоение методов развертывания межсетевых экранов прикладного уровня (WAF), написания пользовательских правил фильтрации L7-угроз, а также проектирование механизмов защиты от DDoS-атак и ограничения частоты запросов (Rate Limiting) на базе обратного прокси-сервера Nginx.



6	masscan/1.3	10006	/api/login	3r/s	5

Задание 1 : Базовая фильтрация угроз через WAF (OWASP Core Rule Set):

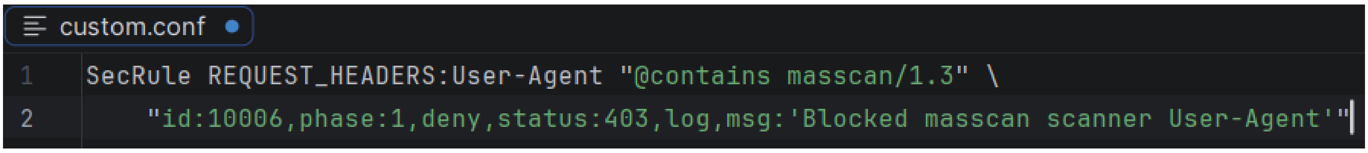


```
D:\Code\skmzs2>curl.exe -i "http://127.0.0.1:5000/?id=1%27%20OR%20%271%27=%271"
HTTP/1.1 200 OK
Server: Werkzeug/3.1.9 Python/3.10.21
Date: Tue, 29 Sep 2026 07:31:19 GMT
Content-Type: text/html; charset=utf-8
Content-Length: 31
Connection: close

Backend OK. Endpoint reached: /
D:\Code\skmzs2>curl.exe -i "http://127.0.0.1/?id=1%27%20OR%20%271%27=%271"
HTTP/1.1 403 Forbidden
Server: nginx/1.30.5
Date: Tue, 29 Sep 2026 07:31:47 GMT
Content-Type: text/html
Content-Length: 153
Connection: keep-alive

<html>
<head><title>403 Forbidden</title></head>
<body>
<center><h1>403 Forbidden</h1></center>
<hr><center>nginx/1.30.5</center>
</body>
</html>
```

Ошибка из-за одинарной кавычки ' внутри URL — curl.exe в Windows её не принимает. Я закодировал кавычку как %27.

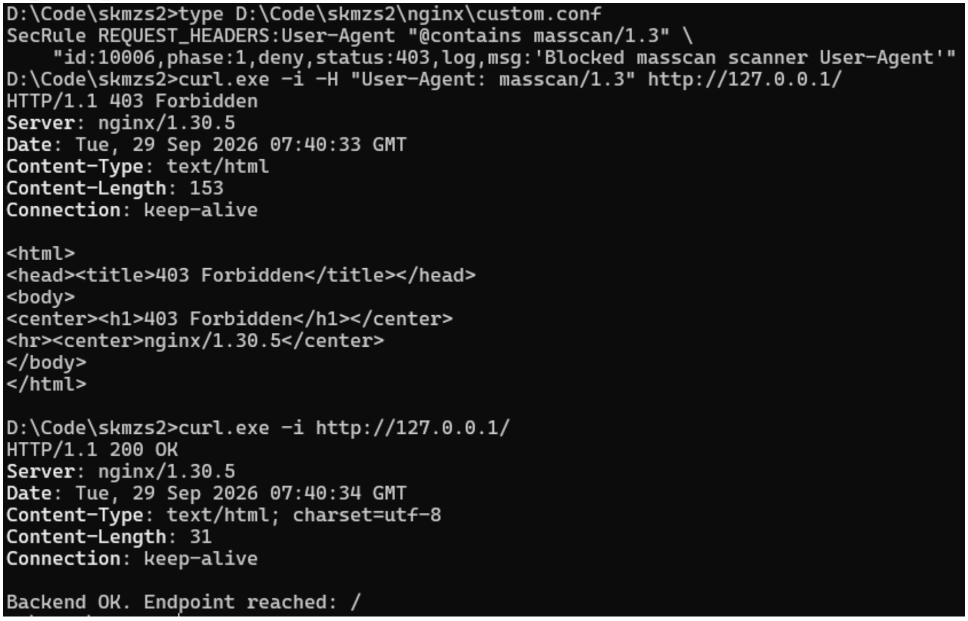
Задание 2: Написание пользовательских правил фильтрации (L7)

`Custom.conf:`



```
SecRule REQUEST_HEADERS:User-Agent "@contains masscan/1.3" \
    "id:10006,phase:1,deny,status:403,log,msg:'Blocked masscan scanner User-Agent'"
```

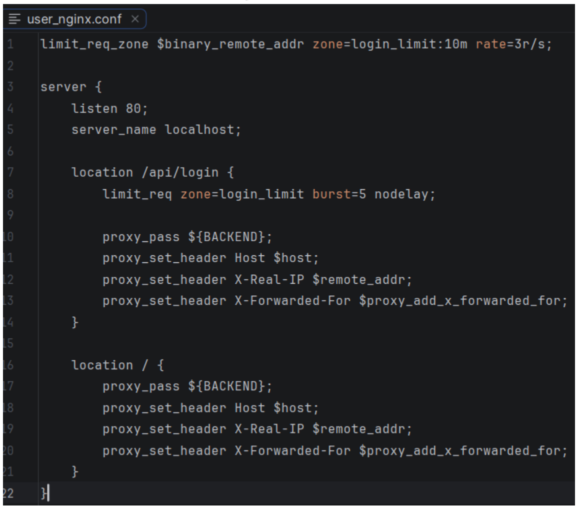
Проверка:



```
D:\Code\skmzs2>type D:\Code\skmzs2\nginx\custom.conf
SecRule REQUEST_HEADERS:User-Agent "@contains masscan/1.3" \
    "id:10006,phase:1,deny,status:403,log,msg:'Blocked masscan scanner User-Agent'"
D:\Code\skmzs2>curl.exe -i -H "User-Agent: masscan/1.3" http://127.0.0.1/
HTTP/1.1 403 Forbidden
Server: nginx/1.30.5
Date: Tue, 29 Sep 2026 07:40:33 GMT
Content-Type: text/html
Content-Length: 153
Connection: keep-alive

<html>
<head><title>403 Forbidden</title></head>
<body>
<center><h1>403 Forbidden</h1></center>
<hr><center>nginx/1.30.5</center>
</body>
</html>

D:\Code\skmzs2>curl.exe -i http://127.0.0.1/
HTTP/1.1 200 OK
Server: nginx/1.30.5
Date: Tue, 29 Sep 2026 07:40:34 GMT
Content-Type: text/html; charset=utf-8
Content-Length: 31
Connection: keep-alive

Backend OK. Endpoint reached: /
```

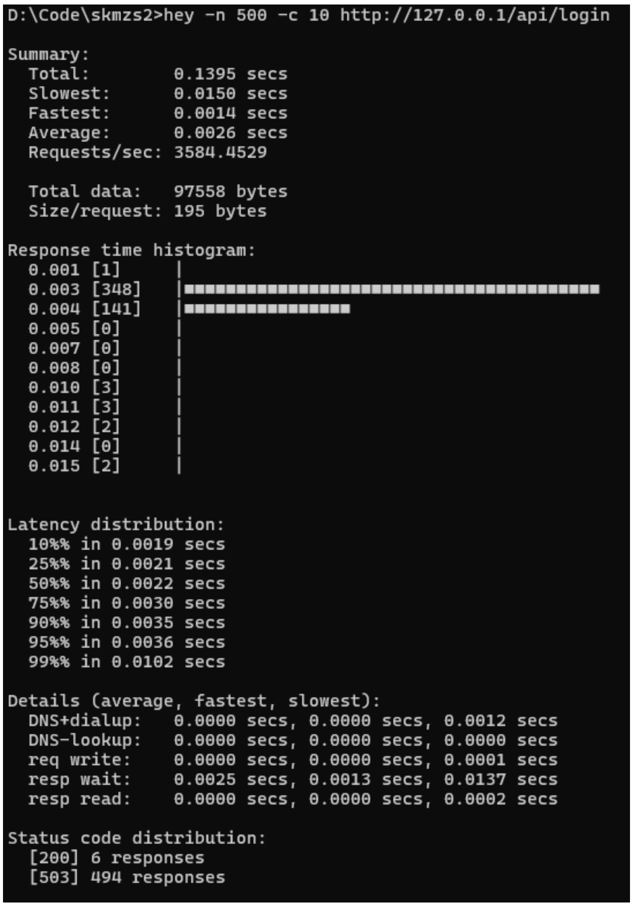
Задание 3: Защита от L7 DDoS-атак (Rate Limiting)

Новый `user_nginx.conf`:



```
limit_req_zone $binary_remote_addr zone=login_limit:10m rate=3r/s;

server {
    listen 80;
    server_name localhost;

    location /api/login {
        limit_req zone=login_limit burst=5 nodelay;

        proxy_pass ${BACKEND};
        proxy_set_header Host $host;
        proxy_set_header X-Real-IP $remote_addr;
        proxy_set_header X-Forwarded-For $proxy_add_x_forwarded_for;
    }

    location / {
        proxy_pass ${BACKEND};
        proxy_set_header Host $host;
        proxy_set_header X-Real-IP $remote_addr;
        proxy_set_header X-Forwarded-For $proxy_add_x_forwarded_for;
    }
}
```

Команда:



```
D:\Code\skmzs2>hey -n 500 -c 10 http://127.0.0.1/api/login

Summary:
  Total:        0.1395 secs
  Slowest:      0.0150 secs
  Fastest:      0.0014 secs
  Average:      0.0026 secs
  Requests/sec: 3584.4529

  Total data:   97558 bytes
  Size/request: 195 bytes

Response time histogram:
  0.001 [1]     |
  0.003 [348]   |■■■■■■■■■■■■■■■■■■■■■■■■■■■■■■■■■■■■■■■■
  0.004 [141]   |■■■■■■■■■■■■■■■■
  0.005 [0]     |
  0.007 [0]     |
  0.008 [0]     |
  0.010 [3]     |
  0.011 [3]     |
  0.012 [2]     |
  0.014 [0]     |
  0.015 [2]     |


Latency distribution:
  10%% in 0.0019 secs
  25%% in 0.0021 secs
  50%% in 0.0022 secs
  75%% in 0.0030 secs
  90%% in 0.0035 secs
  95%% in 0.0036 secs
  99%% in 0.0102 secs

Details (average, fastest, slowest):
  DNS+dialup:   0.0000 secs, 0.0000 secs, 0.0012 secs
  DNS-lookup:   0.0000 secs, 0.0000 secs, 0.0000 secs
  req write:    0.0000 secs, 0.0000 secs, 0.0001 secs
  resp wait:    0.0025 secs, 0.0013 secs, 0.0137 secs
  resp read:    0.0000 secs, 0.0000 secs, 0.0002 secs

Status code distribution:
  [200] 6 responses
  [503] 494 responses
```

Задание 4: Проектирование профилей защиты (Без написания кода)

Конфигурация Nginx для защиты от Slowloris:

```
client_body_timeout 10s;
client_header_timeout 10s;
send_timeout 10s;
keepalive_timeout 5s 5s;
client_max_body_size 1m;
```

Обоснование:

- `client_header_timeout 10s` — если клиент не передал все заголовки за 10 секунд, соединение разрывается. Slowloris-атака строится именно на медленной отправке заголовков, поэтому жёсткий таймаут обрывает такие соединения и освобождает worker connections.
- `client_body_timeout 10s` — аналогично для тела запроса: защищает от медленной передачи POST-данных.
- `send_timeout 10s` — ограничивает время ожидания ответа от клиента после отправки ему данных.
- `keepalive_timeout 5s 5s` — сокращает время удержания keep-alive-соединения, что снижает окно для атакующего.
- `client_max_body_size 1m` — ограничивает размер тела запроса, чтобы злоумышленник не мог занять ресурсы большим POST

Схема CDN + WAF для защиты от L3/L4 DDoS:

Клиент – WAF (L7-фильтрация) – CDN (edge-узлы по миру) –Балансировщик – Серверы приложения

Описание:

- **CDN** принимает трафик на множество географически распределённых edge-узлов. Объёмная атака (L3/L4) «размазывается» по этой инфраструктуре, и до origin-сервера доходит только очищенный трафик. CDN также кэширует статику, снижая нагрузку на бэкенд.
- **WAF** стоит за CDN и анализирует уже очищенный трафик на уровне L7: SQLi, XSS, брутфорс, сканеры. Это второй эшелон защиты.
- **Балансировщик** распределяет оставшийся легитимный трафик по серверам.
- **Origin-серверы** скрыты от прямого доступа — их IP не раскрываются, все запросы идут только через CDN+WAF.

Преимущество: атака L3/L4 «гасится» на периферии CDN, до WAF и серверов доходит только осмысленный HTTP-трафик. Без CDN объёмная атака положила бы канал ещё до того, как WAF успел бы что-то отфильтровать.

Вывод: практически освоил методы развертывания межсетевых экранов прикладного уровня (WAF), написания пользовательских правил фильтрации L7-угроз, а также проектирование механизмов защиты от DDoS-атак и ограничения частоты запросов (Rate Limiting) на базе обратного прокси-сервера Nginx.